EVIDENCIA 01 / REQUISITOS

Requisitos y dimensionamiento NGFW

Diseño técnico basado en la ficha oficial del caso C05 y cálculos reproducibles.

CASO Y ÁMBITO

PagoClaro Fintech S.A.S. (C05), pasarela de pagos y billetera digital. 10 empleados; 20 equipos; entorno híbrido; núcleo transaccional en nube pública y VPN con sede. CAPEX total SOC máximo COP 70 M; OPEX total SOC máximo COP 5 M/mes.

1. Perfil e inventario

Grupo de activos	Cantidad	Servicio / riesgo
Windows 11 escritorio	8	Operación de pagos y atención
Windows 11 portátil	3	Gerencia y cumplimiento
macOS portátil	5	Desarrollo de aplicaciones
Ubuntu Server	4	Bastión, aplicación, réplica de base de datos, respaldo
Total de equipos	20	Switch, NGFW y puntos de acceso no cuentan en estos 20.

2. Requisitos de seguridad y conectividad

Control	Especificación C05
Zonas y segmentos	VLAN Operaciones, Servidores (DMZ interna) y Gestión; firewall inter-VLAN de mínimo privilegio.
Nube y API	VPN IPsec site-to-site entre sede y VPC; la API pública requiere WAF y controles de aplicación adicionales: NGFW no sustituye WAF.
Usuarios híbridos	VPN acceso remoto con MFA, registros de éxito y fallo, GeoIP como señal de riesgo.
Protección NGFW	IPS, control de aplicaciones, antimalware, filtrado web/DNS y descifrado TLS selectivo con excepciones.
Disponibilidad	Dos accesos WAN (si el ISP lo permite); failover medido; HA activo-pasivo opcional y cotizado aparte.
Telemetría a Wazuh	Syslog de VPN, tráfico permitido/denegado, eventos de amenaza, filtrado y cambios de configuración.
Retención de evidencia	Relojes sincronizados, cuentas nominales, segregación de administradores y retención definida por política.

3. Dimensionamiento razonado con margen del 30 %

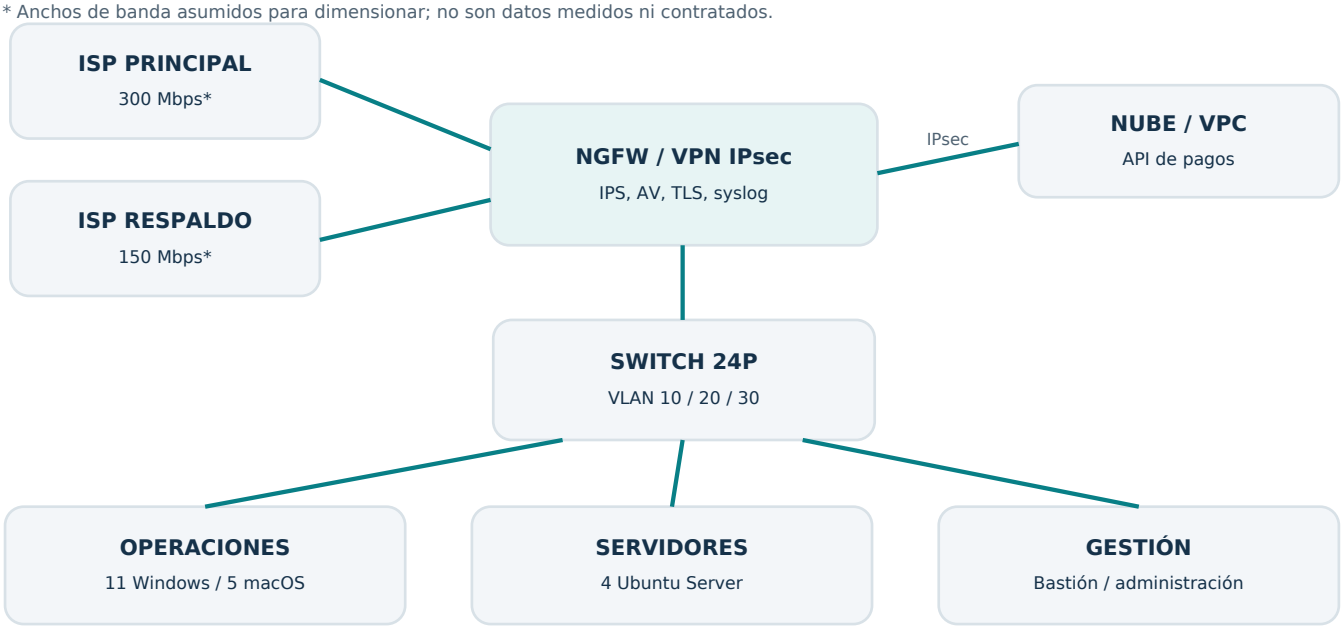
NOTA DE INGENIERÍA

La rúbrica NO informa el ancho de banda contratado ni la concurrencia real de VPN. Para la evaluación se usa un escenario de sede de 300 Mbps primario y 150 Mbps respaldo; no se suman por operar en failover. Se exige medir y confirmar estos parámetros antes de adquirir.

Concepto	Dato / cálculo
Enlace principal hipotético	300 Mbps simétricos.
Enlace secundario hipotético	150 Mbps; no se suma al principal por failover.
Criterio de margen mínimo	30 % sobre tráfico que atraviesa IPS/antimalware.
Meta mínima de protección	300 Mbps × 1,30 = 390 Mbps (0,39 Gbps).
Meta mínima de inspección TLS	390 Mbps como filtro inicial; el impacto real depende de porcentaje HTTPS interceptado.
Sesiones VPN	IPsec sede-nube + remoto con MFA para roles autorizados; cantidad por confirmar.
Capacidad de conexiones	Validar con pruebas de carga del API y crecimiento; no inferir de los 20 equipos.

4. Diagrama lógico de referencia

* Anchos de banda asumidos para dimensionar; no son datos medidos ni contratados.



5. Fuentes y límites

Datos de empresa, flota, riesgos y presupuesto: rúbrica del parcial, ficha C05, página 18. Margen mínimo 30 % y exigencia de capacidad con inspección activa: Fase 5, página 59.

Topología y anchos de banda: arquitectura propuesta para comparación, no infraestructura verificada. El operador de pagos utiliza además controles en nube (WAF, identidad, cifrado y monitoreo).